

Document ID: a-confidential

Corpus ID: tenant-a-support

Tenant: Tenant A

Classification: confidential

Title: Tenant A Retrieval Isolation Incident Review

Fixture status: Synthetic tutorial content

Contains real customer data: No

Tenant A Retrieval Isolation Incident Review

Audience and status

This review is for Tenant A analysts with a confidential-document grant. INC-A-104, REQ-A-204, every operational event, and every organization in this document are fictional tutorial constructs and do not describe a real incident.

Summary

In the fictional scenario, an authenticated user assigned to another tenant submitted an ordinary support question. Vector search returned a relevant Tenant A passage, and the service loaded its original confidential document without a second authorization check.

The test response exposed invented support evidence from INC-A-104 to the wrong tenant session. No real person, customer record, credential, production system, or external service was involved, and the scenario contains no procedure for attacking a system.

Detection and impact

Detection

A fictional quality review compared answer citations with the tenant recorded in REQ-A-204. The reviewer found that the request belonged to a different tenant while one cited source carried the Tenant A corpus and confidential classification.

The review team reproduced the behavior with synthetic fixtures in an isolated tutorial environment. Logs showed that authentication had succeeded, but no document-level authorization decision appeared between candidate ranking and source content loading.

Impact

The modeled impact was limited to invented support evidence in one controlled response. The scenario nevertheless represents a serious boundary failure because authenticated identity alone does not authorize access to another tenant's protected documents.

No real data was processed, and no actual customer was affected. The lesson is that a relevant embedding match must not be treated as permission, regardless of score, citation quality, user authentication state, or apparent similarity between tenant questions.

Cause and remediation

Cause

The fictional pipeline filtered some search candidates by corpus but trusted the resulting identifiers too early. Its content loader accepted a ranked document reference without verifying the principal, action, resource, and context against original metadata.

An internal assumption treated retrieval as a read authorization decision. That assumption collapsed two separate concerns: vector search estimates semantic relevance, while Cedarling evaluates whether the application may perform an action on a protected resource.

Remediation

Customer retrieval data must be isolated by tenant at query time and again before protected content is loaded. The repaired design applies a tenant-scoped search filter, resolves each original document, and authorizes it before reading protected text.

The fictional service now builds authorization input only from server-controlled session state, the requested operation, trusted original-document metadata, and application context. Ranked chunk text never supplies or changes any of those security values.

Verification and closure

Verification

Verification used synthetic users for Tenant A and a separate fictional tenant, with and without confidential-document grants. Tests confirmed that only allowed original documents were loaded, even when an unauthorized chunk received the highest relevance score.

REQ-A-204 was replayed with deterministic fixtures. The cross-tenant candidate remained observable to the controlled test harness for ranking analysis, but the content-loading stage denied it and excluded its text from the model input.

Checkpoints

- Confirm query-time filtering uses the server-selected corpus.
- Confirm every original document receives a fresh authorization decision.
- Confirm denied content is absent from prompts, citations, and responses.
- Confirm decision logs use fictional identifiers and contain no document body.

The fictional review closes INC-A-104 only after negative tests, grant-change tests, and citation checks pass. Future tutorial changes must preserve the separation between retrieval ranking, document authorization, protected loading, and model generation.